

Easyslip Gateway — Live Dashboard

รายงานสำรวจระบบ · 1 พฤษภาคม 2026 · สํารวจผ่าน Chrome MCP

1. URL ที่สำรวจ

```
https://easy-kbank-lb-2569-1097749607619100673.cluster-1.jetder.com/stats/live?key=c057e5233a825208e736b6bd4240431f8b67ad05bc5c3797ac6d718f32fcc874
```

2. คืออะไร

หน้า **real-time monitoring dashboard** ของระบบ **Easyslip Gateway** — เป็น API gateway / load balancer ที่ทำหน้าที่ proxy เรียกรนาการ (จากชื่อ host `easy-kbank-lb` น่าจะเป็นช่องทางไปทสึกร) โฮสต์อยู่บน cluster `jetder.com`

- หน้าเว็บ refresh ทุก **1 วินาที**
- ดึงข้อมูลจาก endpoint `/stats?key=...` ที่คืน JSON
- เก็บ history ย้อนหลัง 10 จุด × window 5 วินาที (ครอบคลุม ~50 วินาที)

3. Metrics ที่หน้า dashboard แสดง

3.1 Throughput (ช่วง 5 วินาทีล่าสุด)

Metric	ค่าที่สำรวจได้	ความหมาย
Incoming TPS	~16–19 req/s	request เข้ามาที่ gateway
Served TPS	~14–18 req/s	ส่งกลับสำเร็จ
Error TPS (5xx)	~0 (spike 0.2/s บางช่วง)	error รายวินาที
Disconnect TPS	0	client ตัดสายระหว่างรอ

3.2 Queue & Concurrency

Metric	ค่า	ความหมาย
Queue depth	0	ไม่มี request ค้างคิว
Upstream in-flight	6–18	request ที่กำลังยังไป backend

3.3 Rate Limiter (Token Bucket)

Config	ค่า
--------	-----

Sustained rate	20 req/s
Burst	50
Window	5 วินาที
Tokens เหลือ (สำรวจ)	~39–50 (ยังไม่ถึง limit)

3.4 Totals (ตั้งแต่ start)

Metric	ค่า
Received	745
Served OK	737
Errors (5xx)	1
Disconnected	0
Uptime	48 วินาที (เพิ่ง restart)

4. โครงสร้าง JSON ของ /stats endpoint

ทดสอบยิง endpoint โดยตรง ได้ `200 OK`, `application/json` โดยมี keys หลัก:

- `current` — snapshot ปัจจุบัน (ts, tps_in, tps_ok, tps_err, queue_depth, upstream_in_flight, limiter_tokens)
- `gauges` — ค่า real-time gauges
- `history` — array ของ snapshots ย้อนหลัง
- `limiter` — config (rate, burst)

5. ⚠️ ข้อสังเกตด้าน Security

Critical: Auth token อยู่ใน Query String

ระบบใช้ `?key=c057e5233a825208e736b6bd4240431f8b67ad05bc5c3797ac6d718f32fcc874` เป็น auth token ซึ่งทำหน้าที่เหมือน password เปิด dashboard

ความเสี่ยง: token ใน URL รั่วได้ง่ายผ่าน:

- browser history
- server access logs (nginx/cloudflare/proxy)
- HTTP `Referer` header เมื่อคลิก link ออกจากเว็บ
- screenshot, screen-share, การส่งต่อ URL ผ่าน chat

คำแนะนำ:

1. **Rotate token นี้ทิ้ง** หากเป็น production (เพราะถูกแฮกซ์เข้า conversation นี้แล้ว)
2. ย้ายไปใช้ header-based auth: `Authorization: Bearer ...`
3. เพิ่ม IP allowlist สำหรับ /stats endpoint (ใช้เฉพาะ ops/internal)
4. พิจารณาใช้ Cloudflare Access หรือ VPN-gated สำหรับ dashboard

ข้อสังเกตอื่น

- URL pattern `easy-kbank-lb-2569-1097749607619100673` บอกใบ้ว่ามีหลาย LB instance (เลข 2569 น่าจะเป็น instance/port id) — ถ้า key เดียวเปิดได้ทุก instance ความเสียหายเมื่อ leak จะกว้าง
- โดเมน `cluster-1.jetder.com` เปิดเผยว่าใช้ infra ของ **Jetder** (Thai cloud/hosting) — info disclosure ระดับต่ำ

6. สรุป

ระบบเป็น **internal ops dashboard ของ rate-limited proxy** ที่ส่ง request ไปกสิกร — สถานะปัจจุบัน **สุขภาพดี** ไม่มี backlog, ไม่มี error สำคัญ, limiter ยังโล่ง

จุดที่ควรปรับ: **วิธี authenticate (ย้าย key ออกจาก query string)**